

第二輪小白卡關修補法律與合規警告 (v3.38)

本檔性質：ConfirmCard TTL 延長、AI 成本入口、備份還原、Undo、客戶 disambiguation 之合規提醒，不構成法律意見。累積適用於 v3.25.10 → v3.37 全部 §6 聲明。

English version: [POLISH_LEGAL_NOTICE_EN.md](#)

⚠️ 重要：v3.38 修補 v3.37 後再盤點之 8 條硬傷

v3.38 涉及：

- ConfirmCard TTL 由 5 分鐘改為 30 分鐘 (N1)
- 撤銷上次 admin 操作 (N2) — 包含公司資料 / 密碼變更回溯 90 秒
- 本機資料庫備份 (N4) — 完整客戶資料複製到 `./backups/` 資料夾
- AI 成本查詢 (N3) — 今日 / 本月 LLM API 用量
- 客戶 disambiguation (N7) — 多筆同名客戶之候選清單
- 業務錯誤中文化 (N6) — ValueError / KeyError 友善訊息
- Chat 取消按鈕 + 手機 responsive (N5, N8)

這些功能錯誤使用可能引發：

- ● ConfirmCard 30 分鐘 TTL 期間，他人經由相同 Session 確認 (資安)
- ● 備份檔含完整客戶資料 → 外流 = 個資法、營業秘密法違反
- ● Undo 90 秒後即失效 — 客戶不應依賴 undo 取代慎重操作
- ● AI 成本 LLM tool 之數據為內部紀錄，不取代雲端 API 廠商之正式對帳單

1. ConfirmCard TTL 由 5 分鐘改為 30 分鐘 (N1)

1.1 動機

- v3.37 客戶反映：「老闆接個電話 5 分鐘卡就過期了」
- 改為 30 分鐘讓使用情境更貼近實際

1.2 副作用 / 風險

- 同一 Session 期間若有他人路過電腦 → 可能點到「確認」執行 hard-write
- 客戶應指導員工：離開座位前鎖屏 (Windows + L / macOS Cmd+Ctrl+Q)
- 公司應建立「30 分鐘無操作自動登出」之配套 (待 v3.x 補)

1.3 法律提醒

- 若有未鎖屏導致誤確認之事件，操作 **audit log** 仍記錄登入帳號為操作者
- 員工應於勞動契約中承認「不分享密碼、不允許他人借用 session」
- 若因員工疏失（未鎖屏）導致誤操作，erpilot 不承擔責任；客戶可依公司管理規章追究

2. Undo Last Admin Change (N2)

2.1 涵蓋範圍

- 公司資料變更 (`set_company_info_with_confirm`)
- 密碼變更 (`change_my_password_with_confirm`)
- 不涵蓋：客戶 / 料件 / SO / PO / 出貨 等業務資料 (v3.x 路線圖)

2.2 限制

- 90 秒內可撤銷；超過時間無法回溯 (in-memory stack)
- 一次只能撤銷最新一筆；不支援多步 redo
- 無持久化：若後端重啟，undo stack 清空
- 不取代正式的版本歷史 / 稽核回溯

2.3 風險提示

- 撤銷密碼變更 = 還原為舊密碼之 hash — 若客戶不記得舊密碼，撤銷後仍無法登入
- 撤銷公司資料變更 = 還原為前一次設定 — 不還原更前面之版本

3. 本機資料庫備份 (N4)

3.1 範圍

- 僅支援 SQLite ; PostgreSQL 客戶須由 IT 用 `pg_dump`
- 備份存於 `./backups/erp-{timestamp}-{note}.db`
- 預設由 `ERPILOT_BACKUP_DIR` 環境變數可改路徑

3.2 備份檔內容

備份檔為完整 SQLite DB copy，含：

- 全部客戶、供應商、料件、訂單之原文資料
- 員工 / 使用者之密碼 hash
- AI 對話紀錄 / audit log

3.3 客戶責任

- 加密儲存備份檔 (推薦 : 7-Zip + AES-256 + 強密碼)
- 異地保存 (本機 + 雲端 + 異廠房)
- 定期測試還原 (建議 : 每季模擬一次「換電腦」流程)
- 保留至少 5 年 (商業會計法 §38)
- 不外流 : 不上傳到公開雲端、不寄 email 附件

3.4 erpilot 之責任邊界

- erpilot 提供功能介面讓使用者觸發備份
- erpilot 不自動排程備份 (v3.x 路線圖)
- erpilot 不自動異地備份
- erpilot 不驗證備份完整性 — 客戶須自行 `sqlite3 file.db .schema` 確認可讀

4. AI 成本入口 (N3)

4.1 資料來源

- `query_ai_cost_today` / `query_ai_cost_this_month` 讀取 `DecisionLog.cost_usd` 欄位
- 此數據由 erpilot 之 governance.py tracker 在每次 LLM call 後寫入

4.2 限制

- erpilot 內部紀錄可能與雲端廠商實際對帳單有出入 (model 升級、bug、tracker 漏記)
- 客戶之正式財務對帳應以雲端 API 廠商之發票 / API console 為準
- 台幣換算採近似匯率 (1 USD ≈ 31.5 TWD) · 僅供參考

4.3 警示閾值

- 日成本 > \$0.5 USD → 顯示「⚠️ 用量較高」
- 月成本 > \$5 USD → 顯示「⚠️ 已超過月度建議預算」
- 客戶可於自家 `governance.py` 調整閾值

5. 客戶 Disambiguation (N7)

5.1 用途

- 講「ABC」如果系統有「ABC 公司」、「ABC 工業」、「ABC 商行」三筆
- `resolve_customer_candidates` 列出 10 個候選 + 編號 + 等級

- 使用者再以編號 / 全名 / 等級確認

5.2 風險

- LLM 不應自動選擇候選 — 應反問使用者
- 客戶須訓練業務：確認候選清單後再下單，否則容易下到錯客戶

6. 業務錯誤中文化 (N6)

6.1 範圍

新增 `ValueError` / `KeyError` 之全域 handler：

- 拋出時若已是中文 → 保留
- 英文則加「輸入值有誤：」前綴
- 加 hint 「請檢查輸入內容...」

6.2 限制

- 不取代深層的 Python traceback log (IT 仍需查 log)
- 未涵蓋的例外：`TypeError`，`AttributeError` 等 — 仍走 `Exception` fallback 「系統忙線中」
- 客戶之特定業務錯誤仍應由 service 層拋出 `BusinessRuleError` 含清楚中文

7. Chat 取消按鈕 + 手機 Responsive (N5, N8)

7.1 取消按鈕

- 使用者等 AI 回答太久可按「■ 取消」
- 前端 `AbortController` 中斷 fetch；後端 LLM 仍可能繼續燒 token (後端 abort 為 v3.x 路線圖)

7.2 手機 responsive

- Chat 在手機瀏覽器 (< 640px) 可用：字小一級、按鈕間距變窄、訊息泡泡寬 92%
- 不等同於原生 App — 仍不支援離線、推播、相機掃條碼
- v3.0 已砍 Mobile App 路線，這只是「桌機 Chat 在手機可用」之過渡

8. 免責條款 (累積適用 v3.25.10 → v3.38)

於適用法律所允許之最大範圍內：

1. **TTL 延長** erpilot 將 ConfirmCard TTL 由 5 分鐘改為 30 分鐘為**功能調整**；客戶須自行加強座位鎖屏 / 自動登出之配套；erpilot **不承擔**因 TTL 延長導致之誤確認損失。
2. **Undo** erpilot 之 `undo_last_admin_change` 為**便利性功能**；不取代正式版本歷史 / 稽核回溯；超過 90 秒即失效；erpilot **不承擔**客戶因依賴 undo 而疏於慎重操作所致之損失。
3. **備份** 備份為**客戶自為**之動作；erpilot 提供工具但**不承擔**備份檔之保管、加密、外流、毀損責任；客戶須依個資法、營業秘密法、商業會計法妥善處理。
4. **AI 成本** `query_ai_cost_*` 為**內部估算**；不取代雲端 API 廠商之正式對帳；客戶於月底結算應以**廠商正式發票**為準。
5. **Disambiguation** 候選清單僅為**搜尋結果**；erpilot 不保證資料庫中之客戶為「合法、現存、有效」之商業實體；客戶須自行確認交易對手身分。
6. **取消按鈕 / 手機 responsive** 前端中止 fetch 不保證後端 LLM 停止運作；手機可用**不等同**支援所有業務情境；客戶須評估自身業務流程是否適用。

9. 客戶導入前 Checklist (v3.38 補強)

導入 erpilot v3.38 前，請確認：

9.1 員工教育 (重要)

- ☐ 30 分鐘 TTL 已告知員工：離開座位請鎖屏
- ☐ Undo 90 秒：講解只能撤銷 admin 操作 / 不可依賴
- ☐ 備份頻率：每週至少 1 次 + 異地保存
- ☐ AI 成本：每月對帳請以雲端廠商發票為準

9.2 內控政策

- ☐ 已建立「離開電腦自動鎖屏」之 IT 政策 (Win + L / 30 分鐘 idle)
- ☐ 已建立「備份檔加密 + 異地」之 SOP
- ☐ 已建立「資料外流回報」之內控流程
- ☐ 已對員工進行 30 分鐘 v3.38 新功能教育

9.3 技術配置

- ☐ `ERPILOT_BACKUP_DIR` 環境變數已設於本機儲存 (不要在 Docker volume 內讓 docker compose down 清掉)
- ☐ 已測試「備份 → 模擬還原」之完整流程
- ☐ 已確認 SQLite → PostgreSQL 升級路徑 (生產環境建議用 PG)

9.4 與既有 checklist 累積

- ☐ 已完成 v3.25.10 → v3.37 之全部 checklist
-

版本：v3.38 (2026-05-21) 作者：erpilot 法務團隊 (內部) 對應程式：

- `backend/app/agents/confirm_card.py` (TTL 改 30 分鐘)
- `backend/app/agents/domains/polish_tools.py` (6 LLM tools)
- `backend/app/agents/domains/setup_wizard_tools.py` (push_undo 整合)
- `backend/app/core/exceptions.py` (ValueError + KeyError handler)
- `frontend-desktop/src/pages/Chat.tsx` (取消按鈕 + mobile responsive)
- `frontend-desktop/src/lib/api.ts` (AbortSignal 支援)